

Analysing the Temporal Dynamics of the Exploit Prediction Scoring Systems (EPSS)

Damiano Ravalico, Mauro Farina, Martino Trevisan, Alberto Bartoli
University of Trieste, Italy

{Corresponding author: damiano.ravalico@phd.units.it, Piazzale Europa, 1 - 34127 - Trieste, Italy}

Abstract—Vulnerability prioritisation is a crucial aspect of cybersecurity, enabling organisations to allocate resources effectively and mitigate the most pressing threats. While traditional methods, such as the Common Vulnerability Scoring System (CVSS), focus on static severity assessments, the Exploit Prediction Scoring System (EPSS) provides a dynamic, data-driven approach to estimating the likelihood of exploitation. However, EPSS has been evaluated only in its ability to select the most appropriate vulnerabilities. In this paper, we take a different perspective and analyse the *temporal dynamics* of EPSS, focusing on how the score of newly disclosed vulnerabilities evolves over time. Using a dataset of over 45000 vulnerabilities tracked since the release of EPSS version 3, we find that EPSS-based prioritisation identifies a comparable number of vulnerabilities to the Cybersecurity & Infrastructure Security Agency (CISA) “Known Exploited Vulnerabilities” catalogue (KEV), however, the EPSS score for a vulnerability requires weeks to reach a critical value. Additionally, EPSS scores exhibit fluctuations over time rather than a steady increase, and the complete metadata in the National Vulnerability Database (NVD) is essential for a vulnerability to reach a high EPSS score. These insights provide a deeper understanding of EPSS as a practical tool and reinforce its role as a complement to traditional vulnerability prioritisation methods.

Index Terms—Vulnerability Prioritisation, Exploit Prediction Scoring System (EPSS), Cybersecurity, Risk Assessment, Temporal Analysis

I. INTRODUCTION

Modern organisations face a constant flood of newly disclosed software vulnerabilities, necessitating an effective *vulnerability prioritisation* strategy to manage and mitigate potential risks effectively. Indeed, while thousands of new vulnerabilities are reported each year, only a small percentage of them are ever exploited in the wild. This makes vulnerability prioritisation essential, as organisations need to focus their limited resources on mitigating the vulnerabilities that pose the most immediate risk.

Traditional approaches to vulnerability prioritisation, often relying on severity scores like the Common Vulnerability Scoring System¹ (CVSS), have been proven inadequate [1–3]. While CVSS provides insights into the potential impact of a vulnerability, it falls short of accurately reflecting the actual likelihood of exploitation. A key reason is that the Base metric group of CVSS scores is systematically assigned and published for almost all vulnerabilities, but these metrics are *static* and do not account for *post-disclosure* information that

can impact exploitation likelihood significantly. For example, the publication of exploits or technical artefacts, which largely increases the odds of attacks, is not reflected in the Base CVSS score.

A metric called the Exploit Prediction Scoring System (EPSS) has been proposed as an additional tool for vulnerability prioritisation. The EPSS score of a vulnerability is a number in the $[0, 1]$ range that estimates the likelihood that the vulnerability will be exploited in the next 30 days. The EPSS of each published vulnerability is updated daily based not only on such static properties of a vulnerability as its Base CVSS and vendor of the vulnerable software but also on a wide range of real-time indicators, such as exploit code availability and social media trends, to gauge the current exploitation activity, acting as a sort of “barometer of cyber weather”. The first EPSS model was published in 2019, while, in 2023, the third version was released. It is important to emphasize that, despite its name, the EPSS is more a form of data-driven *summarisation* of the current threat landscape than an actual prediction [4].

The original study [5] has analysed the effectiveness of the EPSS as a vulnerability prioritisation tool, by assessing its ability to select those vulnerabilities that will actually be exploited in the next 30 days (*coverage*) and to not select vulnerabilities that will not be exploited (*efficiency*). Such study has shown that the EPSS compares very favourably with vulnerability prioritisation strategies based on either the base CVSS score, presence in the Cybersecurity & Infrastructure Security Agency (CISA) “Known Exploited Vulnerabilities” catalogue (KEV), or presence in the Google Project Zero catalogue. This means that for a comparable patching *effort* in terms of the number of vulnerabilities prioritised, selecting vulnerabilities to patch based on their EPSS score results in better coverage and efficiency than selecting them based on these other criteria.

In this paper, we focus on an essential property of the EPSS that was not analysed in the cited studies: its *temporal dynamics*, that is, how the EPSS score of a *newly discovered* vulnerability changes over time, including *how long* it takes for the EPSS score of a vulnerability to reach a critical value. Previous work looked at the set of vulnerabilities known on a given day, the set of vulnerabilities exploited in the next 30 days (collected using proprietary, non-public threat intelligence), and then calculated the coverage and efficiency values resulting from different strategies for constructing the set of prioritised vulnerabilities. Here, we take a different

¹<https://www.first.org/cvss/>

perspective, assuming the point of view of an IT team that prioritises vulnerabilities based on their EPSS score and attempts to gain insights into the resulting prioritisation strategy by investigating such questions as: (i) How quickly does the EPSS determine that a vulnerability needs to be prioritised? (ii) Does the EPSS score tend to grow steadily until it crosses the prioritisation threshold, or does it grow abruptly? (iii) How does the completeness of vulnerability metadata impact the EPSS score?

We carry out a data-driven analysis considering all newly discovered vulnerabilities since the EPSS version 3 model was released. Our dataset includes more than the 45k vulnerabilities released from March 2023 to September 2024, for which we collect EPSS scores on a daily basis. We also consider the evolution of the metadata available in the Common Vulnerabilities and Exposures databases to quantify their impact on the EPSS. Our findings can be summarized as follows:

- Using EPSS for prioritization leads to a volume of vulnerabilities smaller but comparable to using the CISA Known Exploited Vulnerabilities catalogue;
- The EPSS score for a vulnerability requires weeks to possibly reach a critical value, with frequent fluctuations;
- EPSS should be considered as a complement, not a replacement of the other sources. The presence of complete metadata (such as the CVSS and/or CPE) is fundamental for a vulnerability to reach a critical EPSS score.

We believe that the perspective of our work is crucial in assessing the effectiveness of EPSS as a practical tool for vulnerability prioritisation.

The remainder of the paper is organized as follows. Section II provides a description of the datasets utilised in this study. Next, Section III analyses the prioritisation strategy based on EPSS, including comparisons with alternative strategies, Section IV examines the temporal evolution of the EPSS score, and finally Section V investigates the influence of vulnerability metadata on the EPSS score. Section VII summarises the related literature, and Section VIII concludes the paper.

II. DATASET

All our data are obtained from public sources, making our study easily reproducible. To this end, we release the code to run the analysis contained in the paper.²

A. EPSS Score

The EPSS score of a vulnerability is a number in the $[0, 1]$ range that estimates the likelihood that the vulnerability will be exploited in the next 30 days. The EPSS score is updated daily and published on an official API provided by FIRST.³ In this paper, we focus on EPSS version 3, which is the most recent version and has been shown to be significantly more accurate than the previous ones [5]. In EPSS version 3, the score is calculated by a machine learning model that combines

TABLE I: Number of CVE records published and rejected for each year in $\mathcal{D}_{\text{CVE}}$.

Year	Published	Rejected
2021	19 580	393
2022	24 563	212
2023	27 834	135
2024	22 972	224

a diverse set of features which can be conceptually grouped as follows:

CVE database-defined Features extracted from the vulnerability analysis and description in the Common Vulnerability and Exposures (CVE) database. For example, CVSS base score, vendor, and presence of certain keywords.

Community-defined Mention of the vulnerability in certain lists of exploited vulnerabilities (in particular, CISA KEV and Google Project Zero), exploit databases, threat intelligence sources, social media and so on.

We collect EPSS data from the official API, which allows downloading the EPSS score of every vulnerability publicly known on the day of invocation (this notion is defined in terms of the content of the CVE database and will be defined rigorously below). The API also allows downloading the EPSS scores published on a specified past day. The API began providing EPSS values for version 3 on March 7, 2023.

We collected EPSS scores daily from $d_i = \text{March 7, 2023}$ to $d_f = \text{September 30, 2024}$, denoted as the time interval $\mathcal{D}_{\text{EPSS}}$. We denote by $\text{NVD}(d)$ the set of vulnerabilities for which we collected at least one value of EPSS in the time interval $[d_i, d]$. We use the notation NVD to indicate $\text{NVD}(d_f)$, which contains 45 080 vulnerabilities.

B. CVE Database

Based on our initial analyses, the EPSS dynamics often appear to depend significantly on the information currently available in the CVE database for each vulnerability.

For example, we have observed that the EPSS score of a vulnerability tends to increase more significantly when the CVSS or the Common Platform Enumeration⁴ (CPE) of this vulnerability is reported in the CVE database. Such additions often occur several days *after* the vulnerability has been published to the database, and thus an EPSS score for that vulnerability begins to be published.

To gain insight into this important phenomenon, we collected daily snapshots of the CVE database for a time interval $\mathcal{D}_{\text{CVE}}$ from $d'_i = 1 \text{ January 2021}$ to $d_f = 30 \text{ September 2024}$, inclusive (note that $\mathcal{D}_{\text{CVE}}$ and $\mathcal{D}_{\text{EPSS}}$ end on the same day). Specifically, we considered vulnerabilities whose CVE Identifier (CVE-ID) was *reserved* in $\mathcal{D}_{\text{CVE}}$. After a CVE-ID is reserved, either a CVE record for that vulnerability is *published* to the CVE database, or the vulnerability is *rejected*. Table I summarises the number of CVE records published

²<https://github.com/dravalico/paper-freshness-vulnerability-scoring>

³<https://www.first.org/epss/api>

⁴The CPE is a standard, machine-readable description of the specific combinations of software, hardware, and firmware affected by that vulnerability <https://nvd.nist.gov/products/cpe>

and rejected for each year in our analysis. We consider only published vulnerabilities in our subsequent analyses.

Several public services allow downloading CVE information for any specified day, but none of them includes all the information relevant to our analysis. For this reason, we constructed the necessary snapshots by aggregating information from three distinct sources, as follows:

- We use the official *Vulnerability API* by NIST for downloading the full content of the CVE database at the time of invocation.⁵ The database contains one CVE record for each vulnerability, identified by its CVE-ID. The content of a record includes a textual description of the vulnerability, its CVSS, its CPE and other information. Crucially, this information may not be made available atomically at the time the CVE record is created. In many cases, as already observed, such important pieces of information as CVSS and/or CPE are made available several days *after* the creation of the CVE record.
- We used the *CVE Change History API* by NIST for obtaining the list of any changes made to each CVE record, along with the corresponding modification date.
- Finally, since a CVE-ID is often reserved several days before the corresponding CVE record is published in the CVE database, we used the *CVE Project API* by MITRE⁶ for obtaining the reservation date of each CVE-ID, as this date is not available in the official NIST API.

For approximately 5.93% (5632) of CVE records, the Vulnerability API by NIST and the CVE Project by MITRE provide different publication dates. In our analysis, we chose to always use the publication date provided by NIST.

C. Prioritisation Strategies

We take the perspective of the IT department of an organisation that can focus its efforts on a limited set of all vulnerabilities and thus needs to use a systematic vulnerability *prioritisation* strategy. Clearly, any practical instance of a prioritisation strategy would consider whether a given vulnerability indeed affects some systems in the organisation and, if so, the actual risk that a successful exploitation would incur to the organisation. In our analysis, we assume that all vulnerabilities are equally relevant in this respect.

We focus on an EPSS-based vulnerability prioritisation strategy analysed in [5], i.e., we define as NVD_{EPSS} the set of vulnerabilities whose EPSS score reaches a predefined threshold $T = 0.7$ at least once.

We compare this prioritisation strategy to two significant baselines, i.e., the list of vulnerabilities defined as being both severe and actively exploited by two popular and important sources: (i) the CISA catalogue (KEV) and (ii) the Google Project Zero (PZ). Both sources offer a (short) list of CVE-ID as well other a few metadata indicating the reason for being included. We denote as KEV and PZ the set of CVE-ID listed in the KEV and PZ catalogues, respectively. We downloaded a snapshot on date d_f . The KEV catalogue provides the date

TABLE II: Number of vulnerabilities resulting from NVD and selected prioritisation strategies, during period $\mathcal{D}_{EPSS}$.

	Total Size
NVD	45 080
NVD_{EPSS}	137
KEV	182
PZ	68

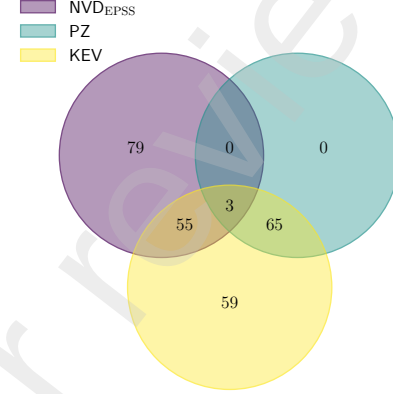


Fig. 1: Venn diagram quantifying the intersections between NVD_{EPSS} , KEV and PZ.

of insertion of each CVE-ID, while the PZ catalogue provides this date only for a few entries.

Notice that these two approaches are fundamentally different and not directly comparable due to the very definition of EPSS. As explicitly stated by the EPSS's authors, if there is the certainty that a vulnerability is being actively exploited, that information should take precedence over an EPSS prediction. Indeed, KEV and PZ list vulnerabilities known to be exploited, while EPSS estimates the likelihood of exploitation within the next 30 days.

III. EPSS FILTERING INTENSITY

We first briefly examine the *filtering* intensity of the EPSS, i.e., we quantify the extent to which an EPSS-based prioritisation strategy provides a security team with a small (or large) set of vulnerabilities to focus on. We compare this strategy with those based on KEV and PZ.

We first characterize the cardinality of the three sets of vulnerabilities resulting from the three prioritisation strategies with Table II: KEV is the largest set (182 elements), while PZ is the smallest (68). Vulnerabilities whose EPSS score has exceeded 0.7 at least once are 137. We then quantify the *similarity* of the sets in Figure 1. Interestingly, about 30% of the KEV entries are in NVD_{EPSS} , suggesting that these sources work on some similar basis and produce similar results (note that the total number of vulnerabilities we consider is more than 45k). We observe that PZ is entirely contained within KEV, with only 3 vulnerabilities shared across all three sets: CVE-2023-36884 (Windows Search Remote Code

⁵<https://nvd.nist.gov/developers/vulnerabilities>

⁶<https://github.com/CVEProject/cvelistV5>

TABLE III: Number of vulnerabilities by attack vector (network and host) in $\mathcal{D}_{\text{EPSS}}$ per prioritisation strategies.

	Network-based	Host-based
NVD_{EPSS}	133	4
KEV	134	48
PZ	32	36

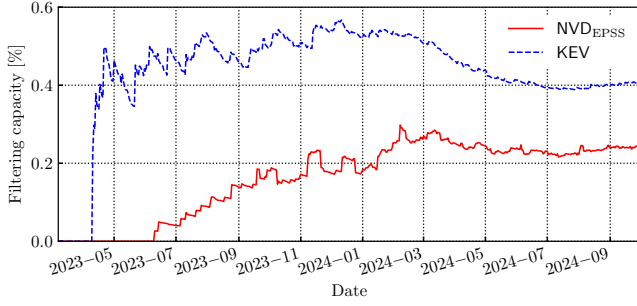


Fig. 2: Filtering capacity of EPSS and KEV measured in terms of the fraction of prioritised vulnerabilities.

Execution), CVE-2023-4762 (Google Chrome Arbitrary Code Execution), and CVE-2023-36761 (Microsoft Word Information Disclosure). Considering that PZ is a subset of KEV and its intersection with NVD_{EPSS} is very small, we omit PZ in the following analyses.

In [5] authors observe a potential bias in the data, as EPSS sources primarily focus on network-based attacks. Our results confirm the phenomenon. In Table III, we break down the number of vulnerabilities prioritized by the three approaches by attack vector. Out of the total 137 vulnerabilities prioritised by NVD_{EPSS} , 133 (97.08%) are network-based, providing potential evidence for the bias hypothesised by the authors of [5]. For comparison, in KEV, only 134 of 182 vulnerabilities (73.63%) are network-based, while, for PZ, only 32 out of 68 (47.06%).

We now take a *dynamic* perspective on NVD_{EPSS} and KEV *filtering capacity* by analysing how it evolves over time. We define filtering capacity as the ratio of the number of vulnerabilities resulting from the prioritisation strategy to the number of published vulnerabilities in the same period. Specifically, let $\text{NVD}(d)$ the set of vulnerabilities in $\mathcal{D}_{\text{EPSS}}$ released until day d , and $\text{NVD}_{\text{EPSS}}(d)$ and $\text{KEV}(d)$ the set of vulnerabilities prioritized on a given day d by EPSS and KEV, respectively. Notice that $\text{NVD}_{\text{EPSS}}(d)$ includes vulnerabilities having a score above the threshold on that specific day, while KEV explicitly reports the insertion date.⁷ We evaluate $\frac{|\text{NVD}_{\text{EPSS}}(d)|}{|\text{NVD}(d)|}$ and $\frac{|\text{KEV}(d)|}{|\text{NVD}(d)|}$ to quantify the evolution of the filtering capacity of the two methods.

Figure 2 provides the time series of filtering capacity for the two strategies (NVD_{EPSS} and KEV) for each day d in $\mathcal{D}_{\text{EPSS}}$. We first observe that both lines start from 0 and present

⁷However, we do not have any information on vulnerabilities added and then removed from KEV, as the database only indicates the addition date, and no explicit removal policy is published.

an irregular shape for the first months. This is expected as both lines are computed as a fraction whose denominator is $\text{NVD}(d)$, which is itself smaller at the beginning of the period. Regarding NVD_{EPSS} (solid red curve), we observe that no vulnerability has reached the EPSS threshold until June 10, 2023. This observation suggests that the filtering strategy resulting from NVD_{EPSS} typically takes several weeks to determine that a given vulnerability should be prioritised (recall that $\text{NVD}(d)$ is the set of vulnerabilities published in $\mathcal{D}_{\text{EPSS}} = [d_i, d]$). This hypothesis is supported by our analyses of EPSS dynamics in the next section. After 10 June 2023, the cardinality of NVD_{EPSS} tends to grow more or less linearly for about a year, and then, after peaking around February 2024, it tends to maintain an approximately constant value around 0.22%, i.e., one should focus on $\approx 0.22\%$ of the number of published vulnerabilities every day (about 1 vulnerability per 400). In other words, after an initial transient phase, the filtering capacity of NVD_{EPSS} settled into a steady state in which the growth rate of the total number of vulnerabilities grew at the same rate as the number of prioritised vulnerabilities.

Regarding KEV (blue dashed curve), the first insertion of vulnerabilities after d_i occurred on 11 November 2023, when 287 vulnerabilities were prioritised. The median number of days between successive insertions is 4 and the curve shows a relatively stable trend from January 2024 onwards, with a filtering settled at about 0.4%, i.e., 1 vulnerability every 250. We find these numbers to be lower than those presented in previous studies, quantifying in 1% to 5% the fraction of vulnerabilities exploited in the wild [6].

To gain further insights into the filtering behaviour of the prioritisation strategies considered, we briefly discuss their relationship with the CVSS Base score. For each vulnerability in NVD, we consider its latest CVSS score. We find that as many as 5412 (12.95%) vulnerabilities are assigned a *critical* CVSS Base score (interval [9.0, 10.0]), which is an order of magnitude larger than the size of NVD_{EPSS} , KEV or PZ. As already pointed out in the literature [1–3], the CVSS is not suitable for prioritising vulnerabilities, both from the qualitative and quantitative points of view. Our data clearly confirm the quantitative aspect.

Restricting to NVD_{EPSS} , we observe that 93% of the vulnerabilities have a CVSS score high or critical (i.e., ≥ 7.0), confirming some of the key findings in [5], especially that EPSS scores tend to reach high values only for vulnerabilities with high CVSS scores, thereby selecting only *some* of those vulnerabilities. Similar considerations hold for KEV: 85% of the vulnerabilities present a high or critical score. That is, both filtering strategies effectively prioritise vulnerabilities assigned with high CVSS scores while having a high CVSS base score is not a sufficient condition for being included in such sets.

Take Away: *NVD_{EPSS} selects approximately 1 vulnerability out of 400 while KEV 1 out of 250. Vulnerabilities prioritised by EPSS tend to be a subset of those having high or critical CVSS base score.*

IV. EPSS DYNAMICS

We now draw attention to the main topic of the paper, i.e., the *dynamics* of the EPSS score. To analyze the temporal

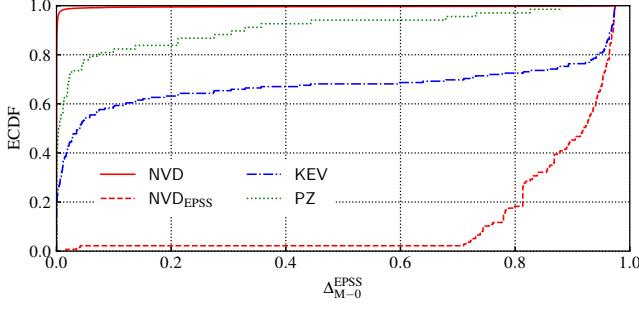


Fig. 3: Distribution of the difference between the maximum and initial EPSS score ($\Delta_{M-0}^{\text{EPSS}}$) across different vulnerability sets.

evolution for each vulnerability, we denote by $\text{EPSS}(v, d)$ the EPSS score of vulnerability v on day d .

We first quantify the extent of the dynamicity of EPSS. Let $\text{EPSS}_M(v)$ denote the *maximum* EPSS score reached by v . We observe that $\text{EPSS}_M(v) \geq 0.01$ for only 877 vulnerabilities (0.008 %) in NVD. This is an interesting observation that complements the findings on filtering capacity in the previous section: not only does NVD_{EPSS} select a very small subset of newly published vulnerabilities for prioritisation, but almost all of these vulnerabilities always have an extremely low EPSS score. Let $\text{EPSS}_0(v)$ denote the *first* EPSS score published for v . We identify as a feature of interest in the EPSS dynamics the difference $\text{EPSS}_M(v) - \text{EPSS}_0(v)$. We denote such a difference as $\Delta_{M-0}^{\text{EPSS}}$ and provide in Figure 3 its distribution over different sets of vulnerabilities.

The solid red curve is the distribution of $\Delta_{M-0}^{\text{EPSS}}$ over all the 45 k vulnerabilities in NVD. For the near totality of such vulnerabilities $\Delta_{M-0}^{\text{EPSS}}$ is very small—indicating they begin with an EPSS score close to 0, which never increases. The solid blue and green curves are the distributions of $\Delta_{M-0}^{\text{EPSS}}$ over KEV and PZ, respectively. It can be seen that $\Delta_{M-0}^{\text{EPSS}}$ is indeed non-negligible for relatively large parts of those sets, in contrast to NVD where $\Delta_{M-0}^{\text{EPSS}}$ is extremely small for almost the full set. From another perspective, the EPSS score of vulnerabilities in KEV and PZ does indeed vary significantly over the lifetime of those vulnerabilities, regardless of whether such a score eventually becomes greater than T . Regarding NVD_{EPSS} (red dashed curve), $\Delta_{M-0}^{\text{EPSS}} \geq 0.7$ for almost all of the vulnerabilities in such a set, meaning that the initial EPSS is very low for most of them. If we analyse the raw data in detail we find only 3 cases in which the initial score was above the threshold: CVE-2023-46805, CVE-2024-21887, and CVE-2024-21893 all with initial EPSS values between 0.98 and 0.99 and final EPSS value at the date d_f further increased. Conversely, for 124 vulnerabilities (90.51 %) in NVD_{EPSS} , $\text{EPSS}_0(v)$ is smaller than 0.01.

Next, we analyse the *responsiveness* of EPSS, i.e., the time it takes to determine that a given vulnerability is indeed worth prioritising. Let $d_0(v)$ be the first day an EPSS is available for vulnerability v and let $d_T(v)$ be the first day $\text{EPSS}(v, d) > T$. In Figure 4, we show the distribution of $\Delta_{\text{EPSS}} = d_T(v) - d_0(v)$ over all vulnerabilities in NVD_{EPSS} . For NVD_{EPSS} , a key

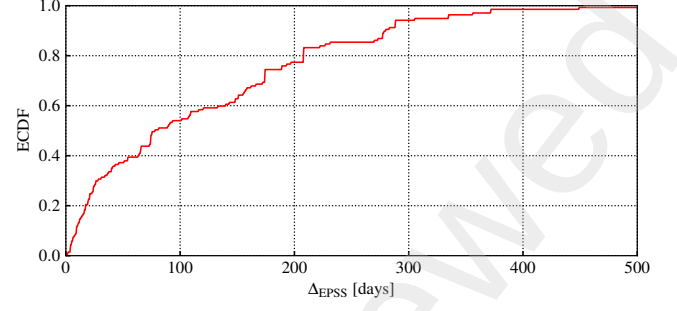


Fig. 4: Distribution of the time taken to reach the EPSS threshold for the vulnerabilities in NVD_{EPSS} .

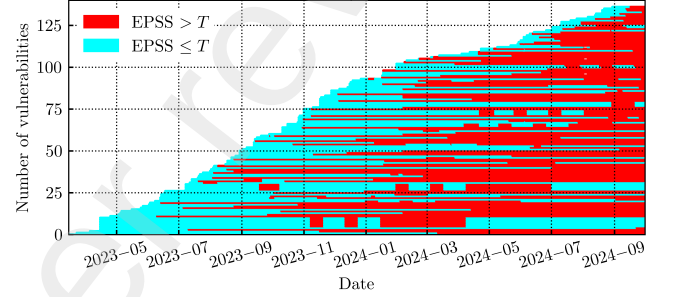


Fig. 5: Qualitative temporal evolution of vulnerabilities within NVD_{EPSS} , sorted by publication time.

finding is that the EPSS only reaches the threshold within a week for 8.03 % (11) of the vulnerabilities. The median Δ_{EPSS} is 78 days and for approximately 40 % of vulnerabilities $\Delta_{\text{EPSS}} \geq 150$ days. In other words, most vulnerabilities become prioritised months after their publication, e.g., 2.92 % (4) of the vulnerabilities took more than one year to reach the threshold.

To offer qualitative insights into the dynamicity of EPSS, we provide in Figure 5 the time intervals in which the EPSS score of each vulnerability in NVD_{EPSS} is greater than the threshold. The figure shows the 137 vulnerabilities in NVD_{EPSS} , arranged in different rows and sorted by their publication time. Each row reports whether the EPSS score of the corresponding vulnerability is above T (red dot) or not (cyan dot) for each particular day. It confirms that in most cases it takes several weeks for the EPSS score to reach the threshold, and only in three cases is the first value of the EPSS score above the threshold. Interestingly, Figure 5 reveals that it is not uncommon for the EPSS score of a vulnerability to reach the threshold and then drop below it, or even to oscillate above and below the threshold. This observation confirms that the EPSS score indeed attempts to provide a *dynamic* estimate of the actual risk posed by each vulnerability and that dynamicity occurs even long after a vulnerability has been published. The evolution of EPSS for the 137 vulnerabilities in NVD_{EPSS} can be summarized as follows:

- Only 92 vulnerabilities maintain an EPSS score always above the threshold T once they surpass it.

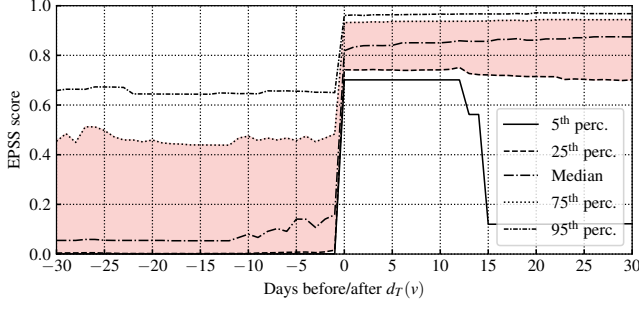


Fig. 6: EPSS score distribution for vulnerabilities in NVD_{EPSS} 30 days before and after they reach the T threshold for the first time.

- 15 vulnerabilities have an EPSS score that exceeds the threshold only temporarily, i.e., it drops below the threshold after some time without rising again.
- 30 vulnerabilities have an EPSS score that oscillates above and below the threshold two or more times—for 11 of these vulnerabilities, the EPSS score on d_f is below the threshold.
- 111 vulnerabilities have an EPSS score that is still above T on d_f .

Curiously, Figure 5 reveals that some vulnerabilities exhibit identical patterns of EPSS score variation. Specifically, we observe that two distinct descriptions are repeated, affecting groups of 3 and 2 vulnerabilities, respectively. A manual inspection confirms that these are duplicates, targeting the same product and version. The figure also highlights 4 additional groups, each consisting of up to 4 vulnerabilities, showing identical EPSS score patterns over time. Upon manual inspection, these vulnerabilities are found to target the same product but in different versions.

Finally, Figure 5 provides an important insight as it reveals that vulnerabilities published in the latter part of the $\mathcal{D}_{EPSS}$ period tend to reach the T threshold for the EPSS score faster than those published earlier. To verify this observation, we divide $\mathcal{D}_{EPSS}$ by grouping vulnerabilities per reservation year—2023 and 2024—and compute the distribution of Δ_{EPSS} separately for each half, i.e., over the vulnerabilities reserved in 2023 and in 2024. The analysis confirms this hypothesis: the median number of days for the EPSS score to reach the threshold before and after the midpoint is 144 days and 24 days, respectively. This notable difference in EPSS responsiveness indicates a substantial disparity in the quantity and quality of information available to the EPSS generation system during the $\mathcal{D}_{EPSS}$ period. We attribute this difference to the responsiveness of the CVE database, which we investigate in more detail in the next section.

We conclude this section by examining the dynamics of the EPSS score as it approaches and surpasses the critical threshold $T = 0.7$. Specifically, we investigate whether the EPSS score tends to increase suddenly from low values to above the threshold or if the threshold is crossed gradually after a phase of steady growth. Importantly, we do not address the broader challenge of predicting if a vulnerability will be

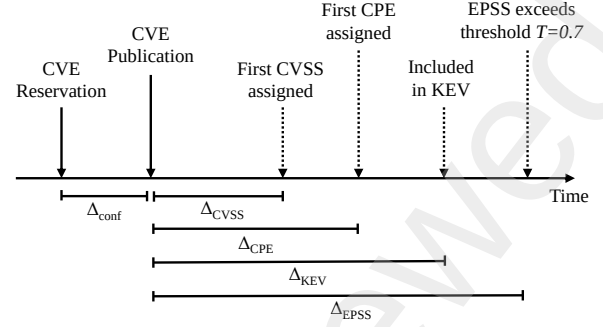


Fig. 7: Key events about CVE records and about inclusion in KEV and NVD_{EPSS} . Dashed arrows indicate events that may occur in a different order or not occur at all.

prioritized by the EPSS model in advance. Instead, our focus is on analysing how often the threshold T is surpassed abruptly or after a more gradual build-up.

In Figure 6, we present the percentiles of EPSS scores for vulnerabilities in NVD_{EPSS} during the 30 days before and after they first surpass the threshold T , i.e., $d_T(v)$. The 5th and the 25th percentiles show that most vulnerabilities have EPSS scores close to zero prior to crossing the threshold. Indeed, 108 out of the 137 vulnerabilities in NVD_{EPSS} exhibit EPSS values below 0.01 on all days before reaching T . The median EPSS score in this period is approximately 0.1, indicating that there is a number of vulnerabilities presenting low but non-close-to-zero EPSS scores. Only 5% of them exhibit scores close to $T = 0.7$ prior to threshold crossing. This suggests that for these vulnerabilities, the threshold is reached after a sustained period of high scores. Post-threshold behaviour reveals interesting trends: the median EPSS score continues to rise moderately but consistently. However, the 5th percentile shows a decline in EPSS scores for a fraction of vulnerabilities in the weeks following the threshold crossing. This highlights the variability in how vulnerabilities are treated by the model over time. In conclusion, for the majority of cases, the EPSS score crosses the threshold T abruptly in a single day rather than through a gradual ramp-up phase.

Take Away: When using EPSS to prioritise vulnerabilities, one should expect typical delays of several weeks or even a few months before a newly published vulnerability attracts attention. Furthermore, you should also expect sudden EPSS increases and cases where the EPSS score shows multiple oscillations around the threshold.

V. THE IMPACT OF CVE METADATA

As mentioned in Section II-B, the EPSS score is computed from many sources, including the information available in the CVE database. In this section, we investigate to what extent the EPSS score depends on whether the vulnerability’s CVSS or CPE is specified in its CVE record. We also measure the impact of a vulnerability to be included in KEV.

To this end, we define the following temporal metrics for each vulnerability (depicted in Figure 7):

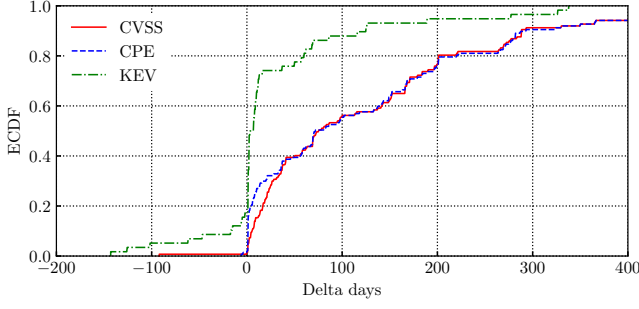


Fig. 8: Delay of inclusion of a vulnerability in NVD_{EPSS} from the publication of its first CVSS, the publication of its first CPE and its inclusion in KEV respectively (i.e., $\Delta_{EPSS} - \Delta_{CVSS}$, $\Delta_{EPSS} - \Delta_{CPE}$ and $\Delta_{EPSS} - \Delta_{KEV}$).

Δ_{conf} Number of days between reservation of the CVE-ID and publication of the CVE record (period during which the CVE record remains confidential).

Δ_{CVSS} Number of days between publication of the CVE record and CVSS assignment.⁸

Δ_{CPE} Number of days between publication of the CVE record and CPE assignment.

Δ_{KEV} Number of days between publication of the CVE record and its (possible) insertion in the KEV catalogue.

Note that for approximately 2.52 % (2396) of CVE records with a CVSS and 1.42 % (1090) with a CPE, the Change History API does not provide the date on which the CVSS or CPE, respectively, has been added. We exclude these records from the corresponding analyses, i.e., we do not suppose the date of metadata insertion.

A. What happens first?

We first focus on the relationship between EPSS and CVE metadata, specifically CVSS and CPE. Here, we investigate whether a vulnerability exceeds the threshold before, after, or on the same day as the publication of their CVSS and/or CPE data. Similarly, we also show the delay between the threshold exceeding and the insertion in the KEV catalogue by CISA. Figure 8 shows the ECDF of $\Delta_{EPSS} - \Delta_{CVSS}$ (solid red line), $\Delta_{EPSS} - \Delta_{CPE}$ (dashed blue line) and $\Delta_{EPSS} - \Delta_{KEV}$ (green dashed line). These three metrics assume positive values if the vulnerability passes the EPSS threshold *after* the other event, otherwise it is negative. Note the three curves include a different number of points, as the CVE records that have a CVSS are not the same number as those that have a CPE and those included in the KEV catalogue.

Regarding CVSS and CPE, we observe that for nearly all vulnerabilities in NVD_{EPSS} , the EPSS score reaches the threshold *after* their CVSS and/or CPE data become available (only 1 and 2 vulnerabilities are inserted in NVD_{EPSS} before the publication of their CVSS and of their CPE, respectively). Specifically, 20 % of the vulnerabilities entered exceed the

⁸Notice that there may exist *more* than one CVSS for a vulnerability, assigned by different bodies at different times. We are interested in the first CVSS assigned.

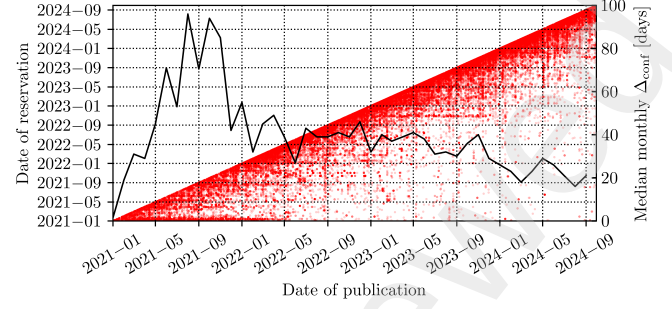


Fig. 9: Scatter plot of publication vs. reservation dates for each vulnerability, with the median monthly Δ_{conf} trend shown by the black line.

threshold on the same day of CPE assignment. While these findings might not be very surprising, they are important because they confirm that prompt publication of CVSS and CPE is crucial for enabling fast vulnerability prioritisation based on the EPSS score. These findings also suggest that EPSS can hardly be a replacement for CVSS assignments and must be seen as a complement.

Figure 8 also shows the distribution of $\Delta_{EPSS} - \Delta_{KEV}$ (green curve). Note that the $\Delta_{EPSS} - \Delta_{KEV}$ measure is defined only for vulnerabilities exceeding the EPSS threshold *and* included in KEV. This happens for the 58 vulnerabilities (see Figure 1). The big step occurring around 0 shows there is typically a small delay between the two events. Specifically, the 50 % (29 vulnerabilities) reach the EPSS threshold the same day or less than one week after the inclusion in KEV. In the median, only 5 days separate the two events, and only the 17.24 % (10 vulnerabilities) show a negative delay, i.e., the insertion inside the KEV catalogue happens *after* they exceed the threshold. This result is particularly important to understand EPSS dynamics: being inserted into the KEV set is a fundamental factor driving the EPSS score, thus KEV readiness has a direct impact.

Now, consider the CVSS base score values for vulnerabilities in NVD_{EPSS} . These vulnerabilities range from 5.3 to 10.0, with the median being 9.8. We observe no evident correlation between CVSS base score and Δ_{EPSS} . Notably, even vulnerabilities with very high CVSS scores can remain below the T threshold for extended periods. CVE-2023-28343 provides an example, having a CVSS base score of 9.8 but $\Delta_{EPSS} = 371$ days.

B. CVE Records' Publication Delay

The previous findings indicate that the delay in prioritising vulnerabilities based on their EPSS score tends to depend heavily on the availability of their CVSS and CPE data. In other words, the EPSS seldom starts to grow before the availability of these data. We now examine the time taken for a CVE record to be published.

We assess the distribution of Δ_{conf} , i.e., the delay between the *reservation* of a CVE-ID and the publication of the corresponding CVE record. This delay provides further

information about the time during which the risk level of a given vulnerability may not be adequately captured simply because it is not yet public—thus, it does not have an EPSS score.

Figure 9 plots the reservation date (left y-axis) against the publication date (x-axis) for each CVE record in $\mathcal{D}_{\text{CVE}}$, one red dot for each. The dots are densely clustered horizontally near the diagonal line, indicating that in most cases the publication of a CVE record occurs shortly after its reservation. However, along each horizontal line, many of the dots are quite far from the diagonal line, indicating a long period during which the vulnerability remains in a confidential state (i.e., reserved but not yet published). In some regions, this effect is particularly pronounced, for example, many of the CVE records reserved around January 2021 took quite a long time to be published, up to 1 year and 4 months. A key observation is therefore that it is common for a vulnerability to remain in a confidential state (i.e. reserved but not yet published) for weeks, and in some cases years. Indeed, 52.79 % of CVE records were published more than 1 month after their reservation; 3.04 % were published more than 1 year after their reservation.

The black curve in Figure 9 plots the median Δ_{conf} on a monthly basis, i.e., across all CVE records *published* in each month (scale on the right y-axis). The curve starts at zero because the $\mathcal{D}_{\text{CVE}}$ dataset includes CVE records *reserved* from January 2021 onwards, i.e., vulnerabilities published from January 2021 onwards that were reserved in 2020 or earlier are not included. The curve peaks in August 2021, corresponding to a median publication time slightly longer than 3 months. Since then, we observe an irregular but persistent downward trend, reaching a minimum of 19 days in August 2024. The median Δ_{conf} computed for vulnerabilities reserved in 2021, 2022, 2023 and 2024 is 53, 39, 35 and 22 days, respectively, thus clearly showing a decreasing trend.

C. CVSS and CPE Availability and Readiness

We now analyse the time it takes for the CVE record of a published vulnerability to include the corresponding CVSS and CPE information eventually. Figure 10a provides the distribution of Δ_{CVSS} across vulnerabilities in $\mathcal{D}_{\text{CVE}}$, separately for different years. Curves for 2021, 2022 and 2023 are very similar, with a median Δ_{CVSS} of 6 days and a steep rise in the distribution indicating that a CVSS was made available shortly after their publication for most vulnerabilities. For approximately 20 % of vulnerabilities, however, from 10 to 20 days were still needed for obtaining the CVSS scoring. This is expected as a certain delay in CVSS publication is well-known [7–10]. In 2024, we observe instead a noticeable difference in the shape of the distribution. More than 70 % include a CVSS already at publication time, much more than the previous years (25 % in 2023 and almost none in 2021 and 2022). On the other hand and most importantly, the remaining 26.67 % vulnerabilities experience much larger values for Δ_{CVSS} . For instance, 12.38 % (8.35 %) of vulnerabilities are assigned with a CVSS only after 30 (60) days. We finally observe that 13.89 % of vulnerabilities reserved in 2024 were still without a CVSS on d_f (September 30, 2024).

Similar considerations hold for Δ_{CPE} , shown in Figure 10b. The median Δ_{CPE} is 6 days for 2021, 2022 and 2023 with an increase for 2024 of just 1 day. However, in 2024, the tail of the distribution gets a heavier tail: 20 % of vulnerability get a CPE after more than one month. Notice that this happened in less than 1 % of cases in the previous years.

We finally dig into the peculiar distribution of Δ_{CVSS} and Δ_{CPE} for 2024, focusing on the number of vulnerabilities still without CVSS or CPE as of d_f . We group CVE records published in each month of 2024 and partition them based on whether they have, or they have not, an associated CVSS or CPE as of d_f . Starting from the CVSS, overall, 13.89 % of vulnerabilities assigned with a CVE-ID in 2024 do not have an accompanying CVSS score on d_f . In Figure 11a, we present these numbers using a bar for each month of 2024. The x-axis represents the months, while the y-axis denotes the number of vulnerabilities published in each month. Vulnerabilities that received a CVSS are shown in green, whereas those without a CVSS are highlighted in red. The months of 2024 can be roughly divided into two groups, with May as the break. Between January and April, the number of published CVE records has an increasing trend, with a moderate fraction of them still being without a CVSS. For instance, in April, approximately 3000 records are published, but less than 500 are without a CVSS as of d_f . In May there is a prominent peak: the number of published CVE records jumps to ≈ 3850 , while the number of those that are still *without* a CVSS is ≈ 1150 , which is a significant growth also in relative terms. Then, from June onwards, the number of CVE records with a CVSS remains more or less steadily around slightly more than 2500 each month while the number of those without a CVSS drops in between 100 to 300.⁹ This analysis confirms that there have been significant difficulties in ensuring prompt analysis of newly discovered vulnerabilities in the early months of 2024. These difficulties appear to have been mitigated but not yet solved in the second half of the year. It is interesting to observe that the green parts of the bars from April onwards are rather constant around the value 2500. This fact might suggest that the maximum *throughput* in processing CVSS that the community can achieve is in the order of 2500 per month. Of course, this is only a rough estimate, as we do not know how the backlog of CVE records not yet assigned a CVSS is being managed, nor do we know whether the criteria for deciding whether to publish a vulnerability has become more or less stringent. It is also interesting to note that from June onwards only 5 % to 10 % CVE records are without a CVSS, less than the initial months of 2024. This observation may indicate that the backlog accumulated between February and April is being processed with less priority than newly discovered vulnerabilities.

Figure 11b shows the same analysis on the CPE. The trends observed for CVSS are more pronounced for CPE. Overall, 64.46 % of vulnerabilities assigned a CVE-ID in 2024 do not have an associated CPE on d_f . January is the only month in which all vulnerabilities have an associated CPE. However,

⁹The small rise of this value in September may be attributed to vulnerabilities that may not have undergone analysis by the end of that month, i.e., by d_f .

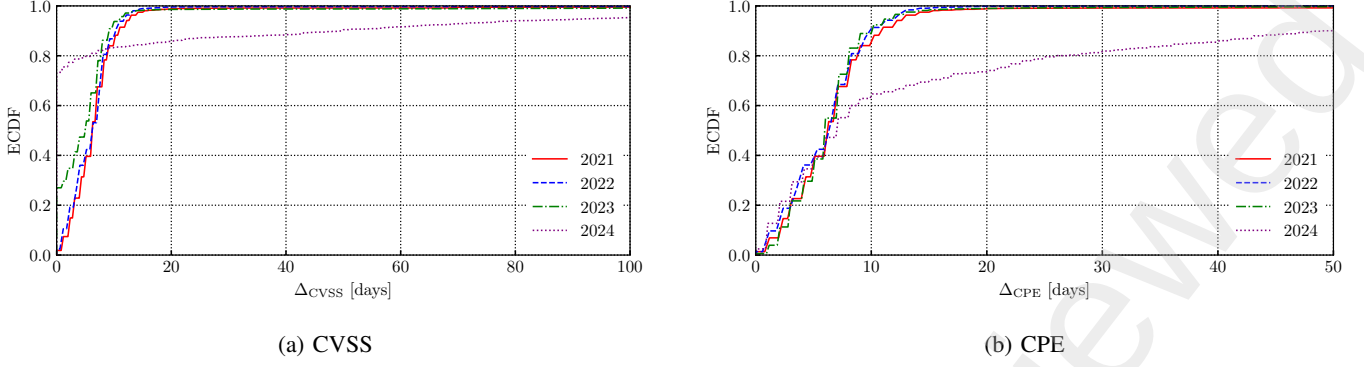


Fig. 10: Number of days to obtain the first CVSS (left) and CPE (right) by reservation year.

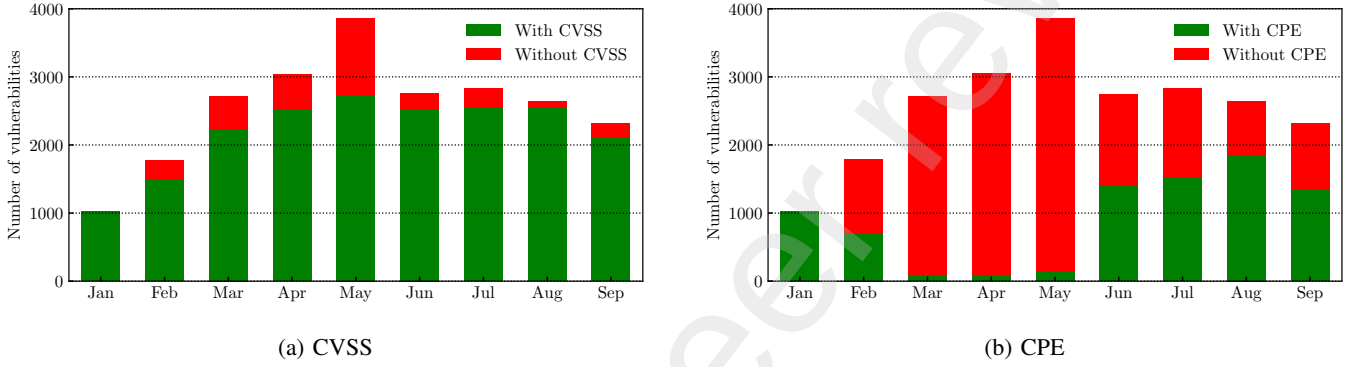


Fig. 11: Monthly amount of new reserved CVEs in 2024 with and without a CVSS (left) and a CPE (right).

the situation quickly and severely deteriorated in the following months, as indicated by the predominance of the red colour. In February, 60.26 % of CVE records lack a CPE, and for March, April, and May, the percentage of records with a CPE is approximately the 3 %. Again, a partial recovery starts from June and July, where 50 % of CVE records are reported to have a CPE. By August, the percentage of records without a CPE decreases to 30 %; similar to CVSS, this percentage increases again in September, reaching 41.73 %.

VI. TOP ROUTINELY EXPLOITED VULNERABILITIES IN 2023

In Section III and Section IV, we utilise the CISA KEV catalogue to evaluate EPSS dynamics. Here, we employ another specialised source of information, also released by CISA, to further examine whether, and mainly when, the EPSS responds to vulnerabilities that have been actively exploited.

The CISA organisation, in collaboration with the cybersecurity agencies of Australia, Canada, New Zealand and the United Kingdom, has released the list of “2023 Top Routinely Exploited Vulnerabilities”.¹⁰ The list was published in late 2024, thus providing an *a posteriori* overview of 2023. We can use it as a ground truth to evaluate EPSS dynamics on frequently exploited vulnerabilities by malicious cyber actors.

The list contains 47 vulnerabilities, but we focus exclusively on those reserved in 2023 and after the release of EPSS model

version 3, as this period aligns with the primary scope of our study. This time interval, spanning from March 7, 2023 (the release of EPSS model version 3) to December 31, 2023, allows us to analyse EPSS prioritization comprehensively. Within this timeframe, 19 vulnerabilities (out of 47) were reserved.

All 19 vulnerabilities are included in the KEV catalogue, with a median Δ_{KEV} of 4 days. However, CVE-2023-36844 and CVE-2023-36845 exhibit a significantly longer Δ_{KEV} of 88 days. Among these 19 vulnerabilities, only 5 meet the T threshold, with a median Δ_{EPSS} of 12 days. Inclusion in KEV happens before reaching the EPSS threshold for four out of these five vulnerabilities. Only one case, CVE-2023-42793, has the difference $\Delta_{EPSS} - \Delta_{KEV}$ of -5 days. Lastly, the median values for both $\Delta_{EPSS} - \Delta_{CVSS}$ and $\Delta_{EPSS} - \Delta_{CPE}$ are 8 days. Interestingly, for all these 5 vulnerabilities, CVSS and CPE were added on the same day.

As noted in the discussion of Table III, the authors of [5] identify a potential bias in the data, attributing it to detection systems predominantly targeting network-based attacks. To verify this claim and assess EPSS model behaviour in prioritization, we manually examined the attack vectors of the 19 vulnerabilities. Of these, 16 are network-based and 3 are host-based. Notably, all 5 vulnerabilities exceeding the T threshold are network-based, supporting the observation that network-based threats dominate the list of the most exploited vulnerabilities in 2023.

¹⁰<https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-317a>

VII. RELATED WORK

A. Vulnerability ranking and prioritisation

The Exploit Prediction Scoring System (EPSS) is related to a growing body of research focused on predicting and detecting vulnerability exploitation. Several industry efforts aim to measure exploit likelihood, but their predictions, evaluations and implementation details are not publicly available [11–13]. Academic research in this field has explored predicting the emergence of proof-of-concept exploits, but not necessarily whether those exploits will be used in the wild [14–20]. Several studies use data from Symantec’s Intrusion Detection System (IDS) to build prediction models [21–24]. Other approaches attempt to predict or detect actual exploitation activity, rather than the mere existence of exploits, by using information extracted from Twitter data [25], patching patterns and blacklist information [26], or natural language processing of dark web discussions [27]. In this respect, a key distinction of EPSS is its focus on predicting real-world exploitation and its nature of community-driven effort, freely available to the public.

A body of work explicitly targeted vulnerability prioritisation and exploitation, thus posing themselves as an alternative to EPSS. In general, they propose new methodologies to quantify to what extent a vulnerability is being exploited or compare existing approaches to this goal. As [28] highlighted, the growing complexity of software and the increasing number of threats make effective vulnerability prioritisation essential. Various approaches have been developed over the years, including risk modelling, machine learning, and optimization techniques [1, 29–32]. For example, [29] introduces a fuzzy systems approach to assess and rank vulnerability risks, improving prioritization by incorporating attack likelihood and exposure beyond CVSS metrics. [1] critiques CVSS for its lack of organizational context and proposes a context-aware method that improves prioritization through simulation, demonstrating significant improvement in prioritization using publicly available data and simulation. [30] presents VULCON, a mixed-integer optimization algorithm that balances time-to-remediation and exposure, tested with real-world scan data under resource constraints. [31] employs word embedding and CNN-based analysis of vulnerability descriptions for prioritization eliminating the need for severity score generation and enabling effective categorization to assist testing teams. Finally, [32] introduces the Context-Aware Vulnerability Prioritization (CAVP) model, integrating temporal characteristics and automation with a Context-Aware Vulnerability Scoring System (CAVSS), validated for organizational risk management. Additionally, a recent work [33] focuses on early exploitability prediction using only CVE descriptions and linked discussions, i.e., at disclosure time, addressing the challenge that existing solutions rely on information unavailable at the time of CVE creation, making them unsuitable immediately after disclosure. The study finds that CVE descriptions and security focus discussions are the most effective training data, while pretrained Large Language Models (LLMs) require further domain-specific training.

In [34], authors emphasize that no one knows which vulnerabilities will be exploited by attackers in any environment, but tools like EPSS leverage metrics to predict potential exploitation candidates. EPSS helps prioritise CVEs in the absence of specific threat intelligence, enriching vulnerability management processes and improving the efficiency of patching strategies, as demonstrated through experiments on vulnerabilities identified in enterprise networks.

B. Accuracy, Timeliness and Consistency of Vulnerability Databases

Research on vulnerability scoring has extensively investigated the accuracy, timeliness, and consistency of vulnerability databases, alongside the methodologies employed to evaluate and prioritise security risks. Building upon prior studies, we extend this research to 2024, the 25th anniversary of the CVE Program [35], by analysing the timeliness of CVE records reserved from 7 March 2023 (the release of EPSS version 3) as these information impact on EPSS dynamics.

Early work [36] analysed trends in CVE records from 2007 to 2010, examining 22 521 entries with a focus on 15 high-frequency vulnerability types. Their study found a 28 % decrease in overall vulnerabilities, with a reduction in high-severity vulnerabilities as well. Notably, they highlighted that over 80 % of vulnerabilities were exploitable via network access without authentication. These trends provide an initial perspective on how vulnerability frequency and severity have evolved over time.

More recent works have critically examined the quality of vulnerability databases, particularly the National Vulnerability Database (NVD). Authors of [37] uncovered inconsistencies in severity scoring, publication timelines, and product naming conventions, which undermined the reliability of NVD database. They found that, while the total number of critical vulnerabilities remained consistent, their proportion decreased over time, and the top 10 vulnerability types among severe cases remained stable across different CVSS versions. Their proposal to automate the cleaning of these inconsistencies highlights the ongoing challenge of ensuring data quality in vulnerability assessment. Similarly, an empirical approach has been followed in [38], where they measure the time delays between the publication of a CVE record inside the NVD and the publication of CVSS. Results show that the CVSS content does not statistically influence the time delays but they are strongly affected by a decreasing annual trend, meaning the time delays have been getting shorter over time.

In addition to examining NVD, researchers have explored cross-database comparisons to assess the consistency of vulnerability scoring across systems. [28] is focused on the relationship between NVD and SonarQube, a service providing severity ratings, revealing a lack of correlation between the two by analyzing 1626 vulnerabilities from June 2023. This finding underscores the difficulty of aligning different vulnerability scoring systems, particularly in environments that rely on multiple databases. Meanwhile, a broader comparative analysis by [39] of U.S. NVD, China’s CNVD, and CNNVD showed both alignment and divergence across these databases.

Although NVD offers a broader range of software vulnerability combinations, CNNVD tends to capture more vulnerabilities related to Chinese vendors. Despite some differences, the temporal correlation between CNNVD and NVD suggests shared sources or tracking practices. They also noted that NVD includes numerous CVE records with missing information such as CVSS or CPE data. These studies emphasize the need for aggregating data across multiple databases to mitigate gaps in coverage and inconsistencies in scoring. Finally, several studies have addressed the statistical reliability of vulnerability scoring methodologies. [40] performed a statistical evaluation of CVSS scores across databases, concluding that NVD is generally reliable for CVSS-based vulnerability assessment. These findings, combined with the proposal from [37] for automation and data improvement, suggest that while the NVD remains a central resource, continuous refinements are necessary to maintain its accuracy and timeliness in vulnerability scoring.

In our work, we study the delays in the NVD CVE database over the last four years. We confirm the findings of previous studies, related to missing or inconsistent data. We also observe a significant delay in completing vulnerability metadata. Our paper provides a detailed analysis of 2024 when the situation appears to have worsened with respect to the previous years.

VIII. CONCLUDING REMARKS

The analyses in this paper provided insights into the temporal dynamics of EPSS scores and their implications for vulnerability prioritisation. We conclude the paper by discussing our key findings and their implications.

As pointed out in the introduction, we are not concerned with the quality of the EPSS scores, that is, with their ability to indeed predict actual exploitation accurately. In this respect, we assumed that EPSS scores are indeed an accurate summary of the overall threat landscape.

Our most important finding is that most prioritised vulnerabilities are identified several weeks or even months after their initial publication. It follows that when an organisation decides that a certain vulnerability is to be prioritised, that vulnerability has been widely known for a relatively long time. This fact confirms that EPSS cannot replace threat intelligence and the need for careful risk assessment of each specific vulnerability. Indeed, our temporal analysis amplifies the relevance of this consideration.

Another important finding is that the EPSS score tends to grow abruptly: the EPSS score of prioritised vulnerabilities in the days immediately preceding their prioritisation is basically indistinguishable from that of non-prioritised vulnerabilities (we note again that we have only provided empirical evidence for this claim, not theoretical proof, as we explained in the discussion of Figure 6). While this may be an inevitable consequence of what is realistically achievable in terms of actually predicting exploitation activity, it also confirms that the exact meaning of the term “prediction” in the EPSS definition is quite subtle: predicting the threat landscape of tomorrow or of the day after tomorrow based on the threat landscape of today is still extremely hard.

The fact that CVSS assignment acts as a sort of starting point for the growth of the EPSS is also worth noting: practically no vulnerability becomes prioritised before its CVSS is assigned and, we observed an increased delay in vulnerability prioritisation along with an increased delay in CVSS assignment. We cannot tell whether CVSS assignment acts as a trigger for exploitation activity, or whether the data-driven process that generates EPSS scores tends to emit very low scores when CVSS-related features are absent even in the presence of exploitation activity. The fact remains, that the latency of CVSS assignment strongly influences the latency in vulnerability prioritisation. This observation also provides a complementary perspective to the feature importance analysis on EPSS scores performed in [5]. According to the cited analysis, the family of CVSS-related features is the third family in determining EPSS scores; and individual CVSS-related features are the 7th to 10th, 19th, 24th and 28th most important contributors. Although our analysis does not aim to analyse the contribution of the many features that are fed into the EPSS model, it seems reasonable to claim that the CVSS assignment alone plays a crucial role in triggering the growth of EPSS. Thus, any vulnerability prioritisation strategy based on EPSS must therefore take into account that vulnerabilities are unlikely to be prioritised until they have received a CVSS score. As we observed, in 2021 and 2022 more than half of the newly discovered vulnerabilities took 1–2 weeks to receive a CVSS, while in 2023 and 2024 this latency increased significantly, with 13 % of the vulnerabilities published in 2024 still without a CVSS on 30 September. This fact not only confirms the importance of rapid analysis of published vulnerabilities for the community but also further confirms that EPSS cannot replace threat intelligence and the need for careful risk assessment of each specific vulnerability—there are simply too many details published about too many vulnerabilities for too long to assume that these vulnerabilities will not be exploited before their CVSS analysis.

In conclusion, our findings provide critical insights for practitioners leveraging EPSS in vulnerability prioritization strategies. Backed by 2023 and 2024 data, we can claim that using EPSS may lead to significant delays and may suffer from the incompleteness of vulnerability metadata in the NVD database. These observations underscore the need for a rigorous, standardized definition of exploitation that integrates quantitative metrics and contextual factors. Furthermore, ensuring that NVD remains up-to-date, consistent and complete is crucial for maximizing the effectiveness of EPSS.

ACKNOWLEDGMENTS

We sincerely thank Professor Fulvio Gini from the University of Pisa for his valuable guidance in defining how to illustrate the prediction challenges associated with EPSS time series effectively.

The research leading to these results has been funded by the COMPACT (Compressed features and representations for network traffic analysis in centralized and edge Internet architectures—2022M2Z728) project, funded by the European Union - Next Generation EU within the PRIN 2022 program (D.D. 104 - 02/02/2022 Ministero dell'Università e della Ricerca) and by the consortium iNEST (Interconnected North-East Innovation Ecosystem) funded by the European Union Next - Generation EU (Piano Nazionale di Ripresa e Resilienza (PNRR) – Missione 4 Componente 2, Investimento 1.5 – D.D. 1058 23/06/2022, ECS 00000043). This manuscript reflects only the authors' views and opinions and the Ministry cannot be considered responsible for them.

REFERENCES

- [1] C. Fruhwirth and T. Mannisto, "Improving cvss-based vulnerability prioritization and response with context information," in *2009 3rd International symposium on empirical software engineering and measurement*. IEEE, 2009, pp. 535–544.
- [2] J. Spring, E. Hatleback, A. Householder, A. Manion, and D. Shick, "Time to change the cvss?" *IEEE Security & Privacy*, vol. 19, no. 2, pp. 74–78, 2021.
- [3] H. Howland, "Cvss: Ubiquitous and broken," *Digital Threats: Research and Practice*, vol. 4, no. 1, pp. 1–12, 2023.
- [4] F. Massacci, "The holy grail of vulnerability predictions," *IEEE Security & Privacy*, vol. 22, no. 1, pp. 4–6, 2024.
- [5] J. Jacobs, S. Romanosky, O. Suci, B. Edwards, and A. Sarabi, "Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights," in *2023 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*. IEEE, 2023, pp. 194–206.
- [6] Cisco, "What's the deal with the massive backlog of vulnerabilities at the nvd?" [Online]. Available: <https://learn.cloudsecurity.cisco.com/vulnerability-management-resources/vmc/prioritization-to-prediction-volume-1>
- [7] NIST, "Nvd program announcement," 2024. [Online]. Available: <https://nvd.nist.gov/general/news/nvd-program-transition-announcement>
- [8] VulnCheck, "Danger is still lurking in the nvd backlog," 2024. [Online]. Available: <https://vulncheck.com/blog/nvd-backlog-exploitation-lurking>
- [9] Fortress, "Nvd cve analysis rate report," 2024. [Online]. Available: <https://www.fortressinfosec.com/nvd-analysis-report>
- [10] Cisco Talos, "What's the deal with the massive backlog of vulnerabilities at the nvd?" 2024. [Online]. Available: <https://blog.talosintelligence.com/nvd-vulnerability-backlog-the-need-to-know/>
- [11] Tenable, "What is vpr and how is it different from cvss?" 2020. [Online]. Available: <https://www.tenable.com/blog/what-is-vpr-and-how-is-it-different-from-cvss>
- [12] Rapid7, "Prioritize vulnerabilities like an attacker," 2023. [Online]. Available: <https://www.rapid7.com/products/insightvm/features/real-risk-prioritization/>
- [13] Recorded Future, "Prioritize patching based on risk. recorded future," 2023. [Online]. Available: <https://www.recordedfuture.com/products/vulnerability-intelligence>
- [14] M. Bozorgi, L. K. Saul, S. Savage, and G. M. Voelker, "Beyond heuristics: learning to classify vulnerabilities and predict exploits," in *Proceedings of the 16th ACM SIGKDD international conference on Knowledge discovery and data mining*, 2010, pp. 105–114.
- [15] M. Edkrantz and A. Said, "Predicting cyber vulnerability exploits with machine learning," in *Thirteenth Scandinavian Conference on Artificial Intelligence*. IOS Press, 2015, pp. 48–57.
- [16] B. L. Bullough, A. K. Yanchenko, C. L. Smith, and J. R. Zipkin, "Predicting exploitation of disclosed software vulnerabilities using open-source data," in *Proceedings of the 3rd ACM on International Workshop on Security and Privacy Analytics*, 2017, pp. 45–53.
- [17] A. Reinthal, E. L. Filippakis, and M. Almgren, "Data modelling for predicting exploits," in *Nordic Conference on Secure IT Systems*. Springer, 2018, pp. 336–351.
- [18] K. Alperin, A. Wollaber, D. Ross, P. Trepagnier, and L. Leonard, "Risk prioritization by leveraging latent vulnerability features in a contested environment," in *Proceedings of the 12th ACM Workshop on Artificial Intelligence and Security*, 2019, pp. 49–57.
- [19] N. Bhatt, A. Anand, and V. S. Yadavalli, "Exploitability prediction of software vulnerabilities," *Quality and Reliability Engineering International*, vol. 37, no. 2, pp. 648–663, 2021.
- [20] O. Suci, C. Nelson, Z. Lyu, T. Bao, and T. Dumitras, "Expected exploitability: Predicting the development of functional vulnerability exploits," in *31st USENIX Security Symposium (USENIX Security 22)*, 2022, pp. 377–394.
- [21] M. Almukaynizi, E. Nunes, K. Dharaiya, M. Senguttuvan, J. Shakarian, and P. Shakarian, "Proactive identification of exploits in the wild through vulnerability mentions online," in *2017 International Conference on Cyber Conflict (CyCon US)*. IEEE, 2017, pp. 82–88.
- [22] H. Chen, R. Liu, N. Park, and V. Subrahmanian, "Using twitter to predict when vulnerabilities will be exploited," in *Proceedings of the 25th ACM SIGKDD international conference on knowledge discovery & data Mining*, 2019, pp. 3143–3152.
- [23] Y. Fang, Y. Liu, C. Huang, and L. Liu, "Fastembed: Predicting vulnerability exploitation possibility based on ensemble machine learning algorithm," *Plos one*, vol. 15, no. 2, p. e0228439, 2020.
- [24] M. S. Hoque, N. Jamil, N. Amin, and K.-Y. Lam, "An improved vulnerability exploitation prediction model with novel cost function and custom trained word vector embedding," *Sensors*, vol. 21, no. 12, p. 4220, 2021.

- [25] C. Sabottke, O. Suci, and T. Dumitras, "Vulnerability disclosure in the age of social media: Exploiting twitter for predicting {Real-World} exploits," in *24th USENIX Security Symposium (USENIX Security 15)*, 2015, pp. 1041–1056.
- [26] C. Xiao, A. Sarabi, Y. Liu, B. Li, M. Liu, and T. Dumitras, "From patching delays to infection symptoms: Using risk profiles for an early discovery of vulnerabilities exploited in the wild," in *27th USENIX Security Symposium (USENIX Security 18)*, 2018, pp. 903–918.
- [27] N. Tavabi, P. Goyal, M. Almkaynizi, P. Shakarian, and K. Lerman, "Darkembed: Exploit prediction with neural language models," in *Proceedings of the AAAI Conference on Artificial Intelligence*, vol. 32, no. 1, 2018.
- [28] M. Esposito, S. Moreschini, V. Lenarduzzi, D. Hästbacka, and D. Falessi, "Can we trust the default vulnerabilities severity?" in *2023 IEEE 23rd International Working Conference on Source Code Analysis and Manipulation (SCAM)*. IEEE, 2023, pp. 265–270.
- [29] M. G. Dondo, "A vulnerability prioritization system using a fuzzy risk analysis approach," in *Proceedings of The Ifip Tc 11 23 rd International Information Security Conference: IFIP 20 th World Computer Congress, IFIP SEC'08, September 7-10, 2008, Milano, Italy 23*. Springer, 2008, pp. 525–540.
- [30] K. A. Farris, A. Shah, G. Cybenko, R. Ganesan, and S. Jajodia, "Vulcon: A system for vulnerability prioritization, mitigation, and management," *ACM Transactions on Privacy and Security (TOPS)*, vol. 21, no. 4, pp. 1–28, 2018.
- [31] R. Sharma, R. Sibal, and S. Sabharwal, "Software vulnerability prioritization using vulnerability description," *International Journal of System Assurance Engineering and Management*, vol. 12, pp. 58–64, 2021.
- [32] B. Jung, Y. Li, and T. Bechor, "Cavp: A context-aware vulnerability prioritization model," *Computers & Security*, vol. 116, p. 102639, 2022.
- [33] E. Iannone, G. Sellitto, E. Iaccarino, F. Ferrucci, A. De Lucia, and F. Palomba, "Early and realistic exploitability prediction of just-disclosed software vulnerabilities: How reliable can it be?" *ACM Transactions on Software Engineering and Methodology*, 2024.
- [34] Orange Cyberdefense, "Exploring the exploit prediction scoring system," 2024. [Online]. Available: <https://www.orangecyberdefense.com/global/blog/research/exploring-the-exploit-prediction-scoring-system>
- [35] CVE Program, "Cve program celebrates 25 years," 2024. [Online]. Available: <https://www.cve.org/Media/News/item/blog/2024/10/22/CVE-Program-Celebrates-25-Years>
- [36] Y.-Y. Chang, P. Zavarsky, R. Ruhl, and D. Lindskog, "Trend analysis of the cve for software vulnerability management," in *2011 IEEE third international conference on privacy, security, risk and trust and 2011 IEEE third international conference on social computing*. IEEE, 2011, pp. 1290–1293.
- [37] A. Anwar, A. Abusnaina, S. Chen, F. Li, and D. Mohaisen, "Cleaning the nvd: Comprehensive quality assessment, improvements, and analyses," *IEEE Transactions on Dependable and Secure Computing*, vol. 19, no. 6, pp. 4255–4269, 2021.
- [38] J. Ruohonen, "A look at the time delays in cvss vulnerability scoring," *Applied Computing and Informatics*, vol. 15, no. 2, pp. 129–135, 2019.
- [39] I. Forain, R. de Oliveira Albuquerque, and R. T. de Sousa Júnior, "Towards system security: What a comparison of national vulnerability databases reveals," in *2022 17th Iberian Conference on Information Systems and Technologies (CISTI)*. IEEE, 2022, pp. 1–6.
- [40] P. Johnson, R. Lagerström, M. Ekstedt, and U. Franke, "Can the common vulnerability scoring system be trusted? a bayesian analysis," *IEEE Transactions on Dependable and Secure Computing*, vol. 15, no. 6, pp. 1002–1015, 2016.